ENTERPRISE RISK MANAGEMENT PROJECT

Governance, Risk and Compliance (GRC)

ERM Consultant: Maureen Uzoewulu

October 13, 2026

Table of Contents

Case Study: PayNest Technologies 4

Company Introduction 4

The Problem 4

Project Deliverables 4

Executive Summary 5

1. Organizational Context & Objectives 7

1.1 Business Context 7

1.2 Business Objectives 8

1.3 Critical Business Processes 9

1.4 Stakeholders and Risk Interests 10

2. Asset Register and Valuation 11

2.1 Valuation Method 11

2.2 Asset register 11

3. Enterprise Risk Identification 13

4. Risk Assessment & Risk Register 15

4.1 Likelihood Criteria 15

4.2 Impact Criteria 15

4.3 Risk Rating Scale 16

4.4 Risk Levels 16

4.5 Risk Register 17

5. Risk Appetite and Tolerance 18

5.1 Risk Appetite and Tolerance Matrix 18

6. STRIDE, PASTA & Attack Tree 22

6.1 Selected System/Asset 22

6.1.1 STRIDE Analysis 22

6.1.2 PASTA Application 23

6.1.3 Attack tree. 25
7. Three Lines Model 26
7.1 PayNest Responsibility Structure 26
8. Risk Treatment Plan 28
9. ISO 31000, COSO ERM & NIST RMF Application 32
9.1 ISO 31000: Enterprise risk-management process 32
9.2 COSO ERM: Governance, strategy, and performance 33
9.3 NIST RMF: Payment-system risk management 34
10. Executive Risk Report 35
10.1 Overall Assessment 35
References 36

Case Study: PayNest Technologies

Company Introduction

PayNest Technologies is a growing Nigerian fintech providing digital payment services through a web and mobile platform. It stores customer information, processes transactions, uses cloud infrastructure, employs about 100 people, and relies on several third-party vendors. Management currently manages risk in silos. There is no comprehensive enterprise-wide risk assessment.

The Problem

Purpose: Conduct a comprehensive enterprise risk assessment for PayNest, identifying assets, risks, appetite, threats, treatment, and governance structure, and communicate findings to management.

Current challenges include:

- Risk is managed in silos across departments
- No enterprise-wide risk assessment has ever been conducted
- No formal asset register or risk register exists
- No defined risk appetite or tolerance levels
- No clear risk ownership or lines of defense
- No structured risk treatment or reporting to the board

Why Does This Matter?

Financial Loss • Regulatory Exposure • Reputational Damage • Operational Disruption • Strategic Missteps

Project Deliverables

1. Organizational Context & Objectives
2. Asset Register & Valuation
3. Enterprise Risk Identification
4. Risk Assessment & Risk Register
5. Risk Appetite & Tolerance
6. Threat Modelling (STRIDE, PASTA, Attack Tree)
7. Three Lines Model
8. Risk Treatment Plan
9. Framework Application (ISO 31000, COSO ERM, NIST RMF)
10. Executive Risk Report

Executive Summary

This assessment evaluates enterprise-wide risks affecting PayNest Technologies, a growing Nigerian fintech providing web and mobile payment services. PayNest stores customer information, processes transactions, uses cloud infrastructure, employs approximately 100 people, and relies on third-party vendors. Its risk management is currently fragmented, with no formal enterprise risk assessment, asset register, defined risk appetite, or clear risk ownership.

The assessment aims to protect customer information, maintain reliable and accurate payments, preserve financial resilience, support compliance, and enable sustainable growth. The report addresses all ten assignment requirements: organizational context, asset valuation, enterprise risk identification, risk assessment, appetite and tolerance, threat modelling, governance, treatment planning, framework application, and executive reporting.

The proposed asset register identifies 14 assets, including customer information, payment applications, transaction records, cloud infrastructure, identity systems, liquidity resources, backups, and customer trust. Assets are valued according to confidentiality, integrity, availability, and business significance rather than unsupported monetary estimates. Ten risks were identified across cybersecurity, financial, operational, compliance, third-party, strategic, reputational, workforce, and governance categories. Using the likelihood × impact method on a 1–5 scale each, three risks received the highest proposed score of 20 and require priority attention: Customer data breach, account takeover and payment fraud, and liquidity or settlement shortfall. The proposed appetite is very low for material customer-data exposure, unauthorized payments, noncompliance, and inability to meet settlement obligations, while allowing controlled commercial uncertainty.

STRIDE, PASTA, and an attack tree were applied to the customer payment platform to connect technical threats with business consequences and defensive controls. The proposed Three Lines structure assigns operational ownership to business departments, oversight and challenge to risk and compliance functions, and independent assurance to Internal Audit. A phased treatment plan prioritizes governance, liquidity validation, and access reviews within 30 days; core control improvements within 90 days; and

resilience testing and assurance within 180 days. ISO 31000 provides the common risk process, COSO ERM connects risk with strategy and performance, and NIST RMF supports system-level control assessment.

Management should approve accountable owners, provisional risk tolerances, and a funded treatment programme, supported by monthly priority-risk reviews and quarterly board reporting. All ratings, thresholds, and residual-risk estimates are proposed assumptions requiring validation. Treatment success must be demonstrated through evidence; a lower numerical score alone does not justify accepting exposure that breaches legal, financial, or customer-protection limits.

1. Organizational Context & Objectives

1.1 Business Context

PayNest Technologies is a growing Nigerian fintech providing digital payment services through web and mobile platforms. It stores customer information, processes transactions, uses cloud infrastructure, employs approximately 100 people, and depends on several third-party vendors. Its risk management is currently siloed, with no comprehensive enterprise assessment, formal asset or risk register, defined appetite, clear risk ownership, or structured board reporting. PayNest's business depends on secure, accurate, and reliable payment processing. Its customer information, transaction records, payment applications, cloud services, people, and vendor relationships form an interconnected operating environment. Rapid growth increases the need to manage risks across departments, not as isolated technical or operational issues.

The business scope covers:

- Web and mobile payment services.
- Customer onboarding, authentication, and account administration.
- Payment initiation, processing, reconciliation, and settlement.
- Customer information and transaction records.
- Cloud infrastructure and supporting technology.
- Finance, employees, customer support, and governance.
- Third-party service providers and contractual dependencies.
- Compliance, business continuity, and reputation.

1.2 Business Objectives

1. ***Deliver reliable payment services*** – Within six months, achieve and maintain at least 99.9% monthly availability for PayNest's customer-facing payment platform, measured through service-monitoring reports and reviewed monthly by the CTO.
2. ***Protect customer information and accounts*** – Within 90 days, implement multifactor authentication for 100% of privileged accounts, complete access reviews for all critical systems, and test customer authentication and account-recovery controls, with identified high-risk weaknesses assigned remediation deadlines.
3. ***Maintain accurate payment records*** – Within 60 days, establish daily reconciliation of all payment and settlement records, ensuring that 100% of discrepancies are investigated and either resolved or formally escalated within one business day of detection.
4. ***Preserve financial resilience*** – Within 45 days, implement a rolling cash flow forecast and daily settlement-liquidity monitoring to maintain sufficient available funds for obligations due and a target unrestricted operating cash runway of at least three months, with any forecast shortfall escalated immediately to the CFO and CEO.
5. ***Meet applicable compliance obligations*** - Within 90 days, establish and validate a register of applicable regulatory, legal, and contractual obligations, assign an owner and deadline to each requirement, and track 100% of mandatory submissions against their applicable due dates.
6. ***Scale sustainably*** – Within 60 days, introduce a formal approval process requiring 100% of material product launches and expansion initiatives to undergo financial, operational, compliance, and security assessments before implementation, with budget variances exceeding 10% submitted for reapproval.
7. ***Maintain customer confidence*** – Within 60 days, implement a documented complaint-management and incident-communication process that triages 100% of urgent payment complaints within one business day and reviews complaint volumes, response times, and recurring issues monthly.

8. ***Build enterprise-wide risk governance*** – Within 30 days, establish an enterprise risk register and assign an accountable owner to every identified material risk; within 90 days, approve treatment plans for all High risks and begin monthly management reviews and quarterly board reporting.

1.3 Critical Business Processes

Processes	Business Purpose
Customer onboarding	Establish legitimate customer relationships and accurate records
Authentication and access management	Restrict account and administrative access
Payment processing	Execute authorized payment instructions accurately
Reconciliation and settlement	Match records and complete financial obligations
Cloud operations	Maintain service performance and availability
Customer support and disputes	Resolve payment issues and protect customer confidence
Incident response and recovery	Contain disruption and restore services
Vendor management	Maintain dependable, outsourced services
Product and change management	Introduce changes without unacceptable exposure

1.4 Stakeholders and Risk Interests

Stakeholders	Main Interests
Customers and merchants	Secure accounts, correct transactions, accessible services
Board and investors	Sustainable growth, financial resilience, transparent exposure
Executive management	Reliable delivery and clear risk accountability
Employees	Clear responsibilities, effective systems, appropriate training
Regulators and supervisory bodies	Compliance with applicable requirements
Banks and payment partners	Accurate settlement, dependable integration, controlled fraud
Cloud and other vendors	Clear responsibilities, contractual performance
Auditors and assurance providers	Reliable evidence and effective governance

2. Asset Register and Valuation

2.1 Valuation Method

Asset valuation is based on business impact, considering confidentiality (C), integrity (I), availability (A), financial significance, regulatory exposure, operational criticality, and reputational consequences. This approach provides a consistent basis for determining asset value and prioritizing protection measures where reliable monetary estimates are unavailable.

Rating definitions:

- ***High***: Compromise could materially affect payments, sensitive information, financial obligations, or business continuity.
- ***Medium***: Compromise could disrupt a function but remain manageable through workarounds.
- ***Low***: Limited business impact and relatively straightforward replacement or recovery.

Overall asset criticality is assessed separately:

- ***Critical***: Essential to customer protection, payment delivery, settlement, or organizational viability.
- ***High***: Important to sustained operations; disruption would cause significant harm.
- ***Moderate***: Supports operations but has practical substitutes or workarounds.

2.2 Asset register

ID	Asset	Owner	Classification	C	I	A	Overall Criticality
A01	A01 Customer Database	Head of Engineering	Confidential	High	High	Medium	Critical
A02	A02 Web and mobile payment applications	Chief Technology Officer (CTO)	Confidential	Medium	High	High	Critical
A03	Transaction ledger and payment records	Chief Financial Officer (CFO	Restricted	High	High	High	Critical

A04	Cloud infrastructure and configurations; backups and recovery	Head of Cloud Operations	Restricted	High	High	High	Critical
A05	Identity and access management system	Head of Engineering	Restricted	High	High	High	Critical
A06	Encryption keys, secrets, and certificates	CTO	Restricted	High	High	High	Critical
A07	Liquidity resources and settlement arrangements	CFO	Restricted	High	High	High	Critical
A08	Source code and deployment pipelines	Head of Engineering	Confidential	High	High	Medium	High
A09	Vendor contracts and integration arrangements	Chief Operating Officer (COO)	Confidential	Medium	High	High	High
A10	Employee endpoints and collaboration systems	IT Operations Manager	Confidential	Medium	High	Medium	High
A11	Customer support and dispute records	Head of Customer Support	Restricted	High	High	Medium	High
A12	Employees and specialist knowledge	Head of Human Resources	Confidential	Medium	High	High	High

3. Enterprise Risk Identification

The following register spans strategic, financial, operational, cybersecurity, compliance, third-party, reputational, workforce, and governance risks.

Category	Risk Statement	Principal Asset
Cybersecurity/Privacy	Weak access controls, vulnerable applications, or cloud misconfiguration could allow unauthorized access to customer information, leading to disclosure, remediation costs, and loss of trust.	A01, A04, A05, A06
Cybersecurity/Financial	Stolen credentials or ineffective account-recovery controls could enable account takeover and unauthorized payments, causing customer losses and disputes.	A02, A03, A05
Operational	Cloud, application, or configuration failure could interrupt payment services, causing lost transactions, delayed processing, and customer dissatisfaction.	A02, A04
Financial	Inadequate cash forecasting, settlement planning, or access to liquidity could prevent PayNest from meeting obligations when due, threatening continuity and partner confidence.	A03, A07
Financial / Operational	Processing defects, duplicate transactions, or weak reconciliation could produce inaccurate balances and settlement records, causing losses and disputes.	A02, A03

Compliance	An incomplete obligations inventory or weak compliance controls could cause failure to meet applicable payment, privacy, customer-protection, or reporting requirements.	A01, A03, A09
Third-party	Failure, compromise, or underperformance of a critical vendor could disrupt services or expose information because of concentrated dependencies and insufficient oversight.	A04, A09
Strategic	Expansion without adequate commercial, financial, operational, and compliance assessment could increase costs and exposure beyond PayNest's capacity.	A02, A07, A12
Reputational	Poor incident communication or unresolved complaints could erode customer confidence and damage commercial relationships.	A11
People/Operational	Employee turnover, insufficient skills, or reliance on key individuals could delay delivery, weaken controls, and disrupt critical processes.	A08, A12
Cybersecurity/Operational	Malicious software or destructive access could encrypt or corrupt systems and backups, causing prolonged disruption and recovery costs.	A04, A10
Governance	Siloed risk management and unclear ownership could leave material exposures unidentified or untreated, causing inconsistent decisions and delayed escalation.	All assets

4. Risk Assessment & Risk Register

Each risk is assessed using a 1 – 5 likelihood scale and a 1 – 5 impact scale, with Risk score = Likelihood x Impact.

4.1 Likelihood Criteria

Score	Rating	Interpretation
1	Rare	Would occur only under exceptional circumstances.
2	Unlikely	Plausible but not expected. Exposure or opportunities for occurrence are limited.
3	Possible	Credible event that could occur, but occurrence is not considered probable.
4	Likely	Significant exposure or repeated opportunities make occurrence probable
5	Almost certain	Persistent conditions make occurrence expected

4.2 Impact Criteria

Score	Rating	Interpretation
1	Insignificant	Minor internal issue; negligible customer impact; loss below 0.1% of annual revenue
2	Minor	Limited disruption or complaints; loss of 0.1% to below 0.5%
3	Moderate	Material departmental disruption or limited customer harm; loss of 0.5% to below 2%

4	Major	Significant service disruption, customer harm, or serious compliance consequences; loss of 2% to below 5%
5	Severe	Threat to continuity, widespread customer harm, major loss of sensitive information, or serious regulatory action; loss of 5% or more

4.3 Risk Rating Scale

		Impact				
		1	**2**	**3**	**4**	**5**
Likelihood	**1**	1	2	3	4	5
	2	2	4	6	8	10
	3	3	6	9	12	15
	4	4	8	12	16	20
	5	5	10	15	20	25

4.4 Risk Levels

Score	Rating	Interpretation
1 – 4	Low	Manage through routine controls and review
5 – 9	Moderate	Assign an owner and monitor against tolerance
10 – 25	High	Require a documented treatment plan and executive oversight

4.5 Risk Register

ID	Risk	Category	Likelihood	Impact	Score	Risk Level
R01	Customer data breach	Cybersecurity	4	5	20	High
R02	Cloud outage	Operational	3	5	15	High
R03	Account takeover and payment fraud	Cybersecurity	4	5	20	High
R04	Payment service outage	Operational	3	5	15	High
R05	Liquidity or settlement shortfall	Financial	4	5	20	High
R06	Reconciliation and processing errors	Financial	4	4	16	High
R07	Failure to meet applicable regulatory, legal, or contractual obligations	Compliance	3	5	15	High
R08	Vendor failure or compromise	Third-party	4	4	16	High
R09	Uncontrolled strategic expansion	Strategic	3	4	12	High
R10	Reputation damage and complaint escalation	Reputational	3	4	12	High
R11	Workforce and key-person dependency	People/Workforce	3	4	12	High
R12	Ransomware or destructive compromise	Cybersecurity	3	5	15	High
R13	Fragmented enterprise risk governance	Governance	4	4	16	High

5. Risk Appetite and Tolerance

Risk appetite describes the amount and type of risk an organization is willing to pursue or retain, and risk tolerance translates that position into acceptable variation around specific objectives. PayNest should pursue measured growth and innovation while maintaining a very low appetite for customer-data exposure, unauthorized transactions, material noncompliance, and failure to meet settlement obligations. It should accept limited, controlled operational and commercial uncertainty where exposures are understood, affordable, and monitored.

5.1 Risk Appetite and Tolerance Matrix

Area	Risk Appetite	Risk Tolerance	Escalation Trigger	Rationale
Cybersecurity and Privacy	Very low	No known unauthorized access to customer data may remain unresolved. 100% of privileged accounts must use multifactor authentication. Critical security vulnerabilities must be remediated or protected by compensating controls within 72 hours.	Any confirmed unauthorized access to customer data; privileged MFA coverage below 100%; a critical vulnerability open beyond 72 hours.	Customer data and payment systems are essential assets; compromise could harm customers, cause financial loss, disrupt operations, and damage reputation.
Financial and settlement	Very low	Available funds must cover payment and settlement obligations due each business day. Daily reconciliation must be completed, and any unreconciled	Forecast available funds are lower than obligations due; daily reconciliation is not completed; or a payment	PayNest must meet payment and settlement obligations reliably to maintain operations and partner confidence.

		payment difference must be investigated within one business day.	difference remains unresolved after one business day.	
Operational	Low	Customer-facing payment-platform availability must be at least 99.9% each month. A critical payment-service disruption must be escalated immediately and restored within the approved recovery-time target.	Monthly availability falls below 99.9%; or a critical payment service is unavailable beyond the approved recovery-time target.	Service availability directly affects customer payments, revenue, support volumes, and reputation.
Compliance	Very low	All applicable regulatory, legal, contractual, and reporting obligations must be recorded, assigned to an owner, and completed by the applicable deadline. No deliberate breach of a legal or regulatory obligation is acceptable.	Missed compliance deadline; unassigned obligation; confirmed noncompliance; or overdue corrective action for a high-rated compliance risk.	Noncompliance may result in sanctions, operating restrictions, customer harm, and reputational damage.
Third-party	Low	Every critical vendor must complete due diligence before onboarding, have a signed agreement, and undergo at least	A critical vendor has no current assessment, contract, continuity plan, or annual	PayNest relies on cloud and third-party providers. Failure or compromise of a provider may affect

		annual performance and risk review. Each critical vendor relationship must have a documented continuity or exit plan.	review, or fails a key service commitment.	payment delivery and customer information.
Strategic growth	Moderate	Every proposed major product launch, market entry, or significant vendor arrangement must complete financial, operational, compliance, and security review before approval. Project spending may not exceed the approved budget by more than 10% without executive reapproval.	A major initiative proceeds without documented approval; an identified High risk has no treatment plan; or forecast spending exceeds the approved budget by more than 10%.	PayNest needs measured innovation and growth, but expansion should not exceed its financial, operational, or compliance capacity.
Reputation and customer service	Low	Urgent payment complaints must be triaged within one business day. Customer-impacting incidents must follow an approved communication and escalation process. Complaint trends must be reviewed monthly.	An urgent payment complaint is not triaged within one business day; an incident communication process is not activated when required; or complaint volumes exceed the approved service threshold.	Prompt customer support and clear incident communication reduce avoidable dissatisfaction and protect trust.

People and governance	Low	Every critical process must have a named owner, current procedure, and at least one trained backup. Every High-rated risk must have an accountable executive owner and documented treatment plan.	A critical process has no backup; a High-rated risk has no owner or treatment plan; or a treatment milestone is overdue without approved extension.	Clear ownership, succession coverage, and risk governance reduce operational dependency and prevent risks from remaining unmanaged.

6. STRIDE, PASTA & Attack Tree

6.1 Selected System/Asset

The threat modelling approaches are demonstrated on PayNest's customer payment platform, including authentication, payment APIs, transaction records and supporting cloud services. STRIDE identifies six threat categories: spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege.

6.1.1 STRIDE Analysis

STRIDE	PayNest Threat Scenario	Business Consequence	Proposed Controls
Spoofing	Attacker impersonates a customer or administrator using stolen credentials	Unauthorized access and payments	MFA, secure recovery, session controls, suspicious-login monitoring
Tampering	Payment instructions or ledger entries are changed without authorization	Incorrect settlement and financial loss	Server-side validation, authorization checks, change controls, reconciliation
Repudiation	A user or administrator denies initiating a payment or altering records	Disputes and weak investigation evidence	Protected audit logs, transaction identifiers, reliable timestamps, restricted log administration
Information Disclosure	An API, database, log, or cloud storage configuration exposes sensitive information	Privacy harm and remediation costs	Encryption, least privilege, data minimization, configuration checks
Denial of Service	Excessive traffic or resource exhaustion prevents payment access	Service interruption and lost transactions	Rate limiting, traffic filtering, capacity management, recovery testing

Elevation of Privilege	A user or compromised account obtains administrative capability	Broad system compromise and fraudulent changes	Privileged access management, separation of duties, access reviews, secure development

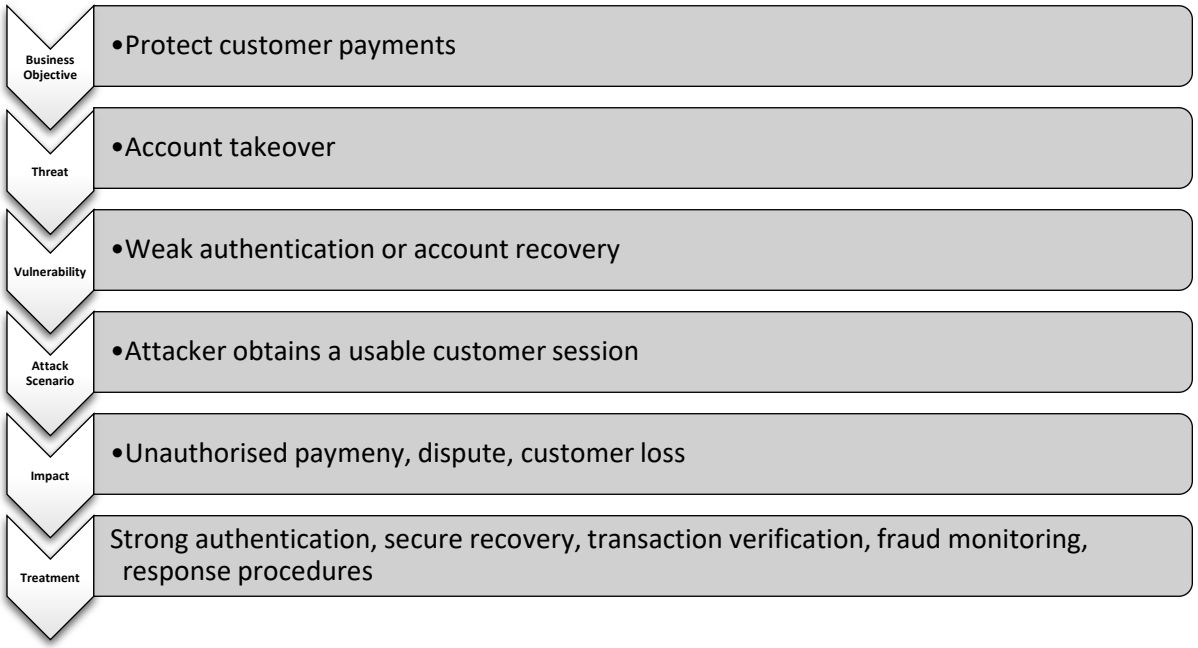
6.1.2 PASTA Application

PASTA links business objectives to technical threats, vulnerabilities, attack scenarios, and risk treatment through seven stages.

PASTA Statge	PayNest Application	Output
1. Define business objectives	Protect customer funds, maintain accurate payments, preserve service availability	Business-impact and risk objectives
2. Define technical scope	Include customer clients, APIs, identity services, payment engine, databases, cloud, and partner integrations	Scope and dependency inventory
3. Decompose the application	Map data flows, identities, entry points, permissions, and trust boundaries	Validated architecture and data-flow diagrams
4. Analyze threats	Consider account takeover, malicious insiders, API abuse, and vendor compromise	Threat scenarios and relevant intelligence
5. Analyze vulnerabilities	Test possible weak recovery, broken authorization, excessive permissions, and logging gaps	Evidence-backed findings

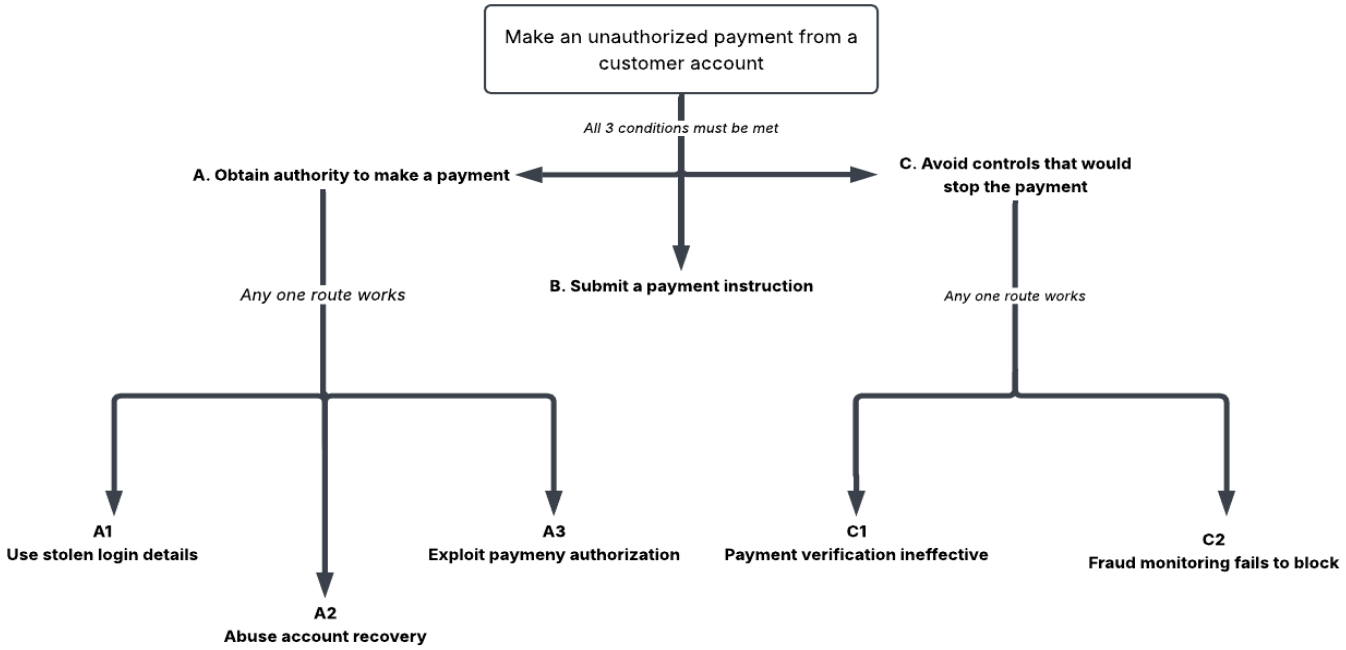
6. Model and simulate attacks	Conduct authorized nonproduction tests using synthetic accounts and transactions	Control-performance evidence
7. Analyze and manage risks	Assess financial, customer, operational, and compliance effects; prioritize controls	Updated risk assessments

6.1.2.1 Illustrative attack chain



6.1.3 Attack tree.

The goal of the attack tree illustrated below is to execute an unauthorized payment from a customer account. It shows how an attacker could cause PayNest to execute an unauthorized customer payment. The attacker must obtain payment authority, submit an accepted payment instruction, and avoid controls that would prevent execution. Alternative access routes include stolen credentials, account-recovery abuse, and weaknesses in payment authorization. The tree supports control prioritization by showing where authentication, authorization, payment verification, and fraud prevention can interrupt the attack.



7. Three Lines Model

PayNest's Three Lines Model establishes accountability for managing risk, monitoring controls, and independently assessing whether those controls work. It separates three complementary responsibilities:

- First line: Own and manage risks in daily operations.
- Second line: Provide expertise, support, monitoring, and challenge.
- Third line: Provide independent assurance on governance, risk management, and controls.

The Board oversees these arrangements. Both the first and second lines are part of management; Internal Audit operates independently from management responsibilities.

7.1 PayNest Responsibility Structure

Governance Position	PayNest Functions	Responsibilities
Governing Body	Board / Risk and Audit Committee	Approve appetite; oversee executive risk ownership; challenge exposures and treatment progress; protect Internal Audit's independence
First Line	Engineering, Cloud Operations, Payment Operations, Finance, Customer Support, HR, and vendor relationship owners	Identify risks; design and operate controls; investigate incidents; implement treatments; report breaches and progress
Second Line	ERM lead, Compliance, privacy oversight, and security governance	Set assessment methods and policies; advise owners; monitor tolerances; challenge ratings and treatment

		plans; consolidate enterprise reporting
Third Line	Independent Internal Audit or outsourced internal audit provider	Independently assess whether governance, risk management, and controls are effective; report weaknesses and verify corrective action

Example

Customer data breach (R01):

1) **First Line** (*Manage it*) - Engineering implements MFA, restricts permissions, protects data, and responds to incidents.
2) **Second Line** (*Monitor and Challenge*) - Security governance and privacy oversight review policy compliance, access exceptions, and incident trends.
3) **Third Line** (*Independently Assess*) -Internal Audit samples access rights and evaluates whether controls and incident procedures work.

8. Risk Treatment Plan

The Risk Treatment Plan sets out PayNest Technologies' proposed response to each risk identified in the enterprise risk register. It specifies the treatment approach, Avoid, Reduce, Transfer, or Accept, along with recommended actions, accountable owners, controlss, and expected residual risk.

Actions are prioritized according to risk scores, potential business consequences, and PayNest's proposed risk appetite and tolerance. The plan provides a basis for allocating resources and holding risk owners accountable. Expected residual-risk ratings remain provisional until the recommended controls have been implemented and their effectiveness verified.

ID	Risk	Treatment	Controls	Owner	Residual Risk
R01	Customer data breach	Reduce	Enforce privileged MFA; review access; validate cloud configurations; protect sensitive data; improve logging and response; evaluate suitable cyber insurance	CTO	High
R02	Cloud outage	Reduce	MFA, Privileged Access Management, monitoring	Head of Cloud Operations	Medium
R03	Account takeover and payment fraud	Reduce	Strengthen authentication and recovery; validate payment authorization; apply transaction	COO	Moderate

			verification and fraud monitoring; define customer-remediation procedures		
R04	Payment service outage	Reduce;	Define recovery architecture; test backups and restoration; improve monitoring; document vendor escalation and contractual remedies	CTO	Moderate
R05	Liquidity or settlement shortfall	Reduce	Introduce rolling cash forecasts, settlement coverage monitoring, stress testing, and escalation; defer commitments that would breach approved limits	CFO	Moderate
R06	Reconciliation and processing errors	Reduce	Automate daily reconciliation where feasible; investigate exceptions; prevent duplicate processing; separate adjustment and approval duties	CFO	Moderate
R07	Failure to meet applicable regulatory, legal, or contractual obligations	Reduce	Build obligations register with qualified advice; assign duties; monitor deadlines; validate	Head of Compliance	Moderate

			controls before regulated activity or expansion		
R08	Establish launch gates, business cases, downside analysis, staged investment, and stop/go criteria	Reduce	Classify critical vendors; conduct due diligence; strengthen contracts; monitor performance; test exit and continuity arrangements	COO	Moderate
R09	Uncontrolled strategic expansion	Reduce; Avoid unjustified expansion	Establish launch gates, business cases, downside analysis, staged investment, and stop/go criteria	CEO	Moderate
R10	Reputation damage and complaint escalation	Reduce	Establish complaint escalation, incident communication, support training, and trend monitoring	Head of Customer Support	Moderate
R11	Workforce and key-person dependency	Reduce; Accept controlled remainder	Crosstrain staff; maintain runbooks; identify succession and backup coverage; address specialist skills gaps	Head of Human Resources	Moderate
R12	Ransomware or destructive compromise	Reduce	Implement endpoint protection, patching, segmentation, protected backups, and a ransomware response exercise	CTO	Moderate

R13	Fragmented enterprise risk governance	Reduce	Appoint ERM coordinator; approve ownership and appetite; establish registers, reporting, and quarterly reviews	CEO	Moderate

9. ISO 31000, COSO ERM & NIST RMF Application

These frameworks complement each other. At PayNest, ISO 31000 is the overall risk process, COSO ERM is the strategy and performance framework, and NIST RMF is the system-level cybersecurity and privacy risk approach. They are complementary, not interchangeable.

9.1 ISO 31000: Enterprise risk-management process

Element	Application at PayNest
Principles	Embed risk in business decisions; use stakeholder input; adapt to growth; recognize human factors and uncertainty
Framework	Establish leadership commitment, roles, resources, evaluation, and improvement
Communication and Consultation	Engage Finance, Engineering, Operations, Compliance, HR, customers, and vendors as appropriate
Scope, Context and Criteria	Define payment-service boundaries, objectives, assessment scale, and appetite
Risk Assessment	Identify scenarios, analyze consequences, evaluate against appetite
Treatment	Select proportionate actions and assign owners
Monitoring and Review	Review incidents, business changes, controls, and risk trends
Recording and Reporting	Maintain traceable decisions and board reporting

PayNest should apply this process during launches, major changes, vendor onboarding, and periodic enterprise reviews, not only after incidents.

9.2 COSO ERM: Governance, strategy, and performance

The COSO ERM Framework has five components:

Component	Application at PayNest
Governance and Culture	Board oversight, clear ownership, ethical conduct, escalation expectations
Strategy and Objective-setting	Evaluate expansion choices against liquidity, capability, compliance, and appetite
Performance	Prioritize risks and consider aggregate exposure and interdependencies
Review and Revision	Reassess after incidents, changes in services, vendor events, or missed objectives
Information, communication, and reporting	Consolidate indicators and risk decisions for management and the Board

For example, a proposed payment-service expansion should require a joined-up decision on commercial benefit, settlement capacity, vendor reliance, customer protection, and operational resilience. A collection of separate departmental approvals would not provide the same enterprise view.

9.3 NIST RMF: Payment-system risk management

This framework is used to manage cybersecurity and privacy risks in information systems through seven repeatable steps.

Step	Application at PayNest
Prepare	Establish system ownership, stakeholders, boundaries, and risk responsibilities
Categorize	Assess consequences of losing confidentiality, integrity, and availability
Select	Choose proportionate controls for identity, authorization, logging, configuration, recovery, and privacy
Implement	Deploy controls and document responsibilities across PayNest and vendors
Assess	Test whether controls operate as intended
Authorize	Have the designated executive decide whether system exposure is acceptable
Monitor	Track control performance, vulnerabilities, incidents, and material changes

10. Executive Risk Report

10.1 Overall Assessment

PayNest's growth has outpaced its enterprise risk-management structure, revealing fragmented risk practices, missing registers, undefined appetite, unclear ownership, and limited board reporting. Management should immediately establish governance and validate the highest-consequence exposures. The assessment identifies 13 enterprise risks. All initially fall within the adopted High band, reflecting a conservative planning baseline rather than verified control failures. Three score 20 and receive urgent priority:

- Customer data breach (R01)
- Account takeover and payment fraud (R03)
- Liquidity or settlement shortfall (R05)

Recommended actions include

- Enforce MFA across all customer and employee accounts.
- Implement least privilege and privileged access management.
- Strengthen cloud redundancy and negotiate SLA guarantees.
- Conduct continuous vulnerability assessments.
- Improve employee phishing awareness.

Medium residual risk remains due to evolving cyber threats and third-party dependencies. These risks could cause financial losses from fraud and downtime, regulatory penalties, severe reputational damage, and customer churn.

PayNest should prioritize cybersecurity maturity, strengthen governance, and adopt integrated enterprise-wide risk management. Implementing MFA, improving monitoring, and aligning risk appetite with strategic objectives will significantly reduce exposure and support sustainable growth.

References

1. Bello-Abubakar, A. (n.d.-a). *Enterprise risk management* [Training slides]. 10Alytics
2. Bello-Abubakar, A. (n.d.-b). *Enterprise risk management project* [Capstone assignment slides]. 10Alytics.